

Assignment, WASP Software Engineering Course Module

Sönke Jendral

June 2026

1 Introduction

In 1994, Peter W. Shor published a method for efficiently solving two fundamental mathematical problems, discrete logarithms and integer factorisation, by using quantum computing [7]. This novel method, commonly referred to as *Shor's algorithm*, threatens the security of many cryptographic algorithms that are currently in widespread use and has motivated the need to migrate to new, post-quantum cryptographic (PQC) algorithms that are not vulnerable to this attack. Importantly, advances in quantum computing, including recent works such as [2, 3], show that the threat posed by quantum computing is credible, and ongoing migration efforts across the internet are planned to be completed no later than 2035 [6]. Both Google and Cloudflare have announced even more ambitious migrations with deadlines in 2029 [1, 9]. Put differently, this migration effort is actively underway at an unprecedented scale and under significant time pressure.

On the cryptographic side, since 2016 much of the work has been driven by the National Institute of Standards and Technology (NIST) across two standardisation competitions [8]. In these competitions, NIST aims to identify the most suitable algorithms for future standardisation, based on not only their cryptographic soundness, but also on practical considerations for their use, such as the size of the involved ciphertexts or the performance of the procedures. Our research focuses on the implementation security of the candidates (and winners) of these competitions. Specifically, we are considering so-called *side-channel attacks*, where an attacker has physical access to a device running a cryptographic algorithm and can observe or interfere with certain physical characteristics, such as the power supply, with the goal of recovering secret information. While passive side-channel attacks commonly make use of machine learning techniques, my work focuses on active fault injection attacks and does not make use of machine learning in any capacity.

From a software engineering perspective, our research does not involve significant development work. In particular, we mainly focus on analysing existing implementations of PQC algorithms, not on developing novel implementations,

thus most of the work is mathematical and software is only written to experimentally demonstrate the feasibility of an attack. Furthermore, the potential productionisation of attacks capable of breaking real-world cryptography raises a number of ethical and legal concerns and is therefore expressly not part of our research goals.

2 Lecture principles

Behavioural software engineering. A central observation in behavioural software engineering is the notion that humans may not use technology in a rational manner. The research from CCS 2023 on how AI assistance may cause more insecure code to be written has a direct relation to our research and highlights that it may not be enough to provide better tools. The first guest lecture slides even demonstrate this problem in practice: There is a slide listing a requirement that "All communication shall be encrypted with SHA-2.", which is obviously nonsensical, since the SHA standard(s) specify hash functions that have nothing to do with encryption. If used rationally, an LLM might push back on this type of nonsensical requirement, but a novice user may not then be able to articulate the correct requirement. Worse yet, a user may use a tool to generate code despite a flawed requirement and not be able to identify subtle security issues. At the same time, LLM-assisted vulnerability tools have caused a substantial increase in reported vulnerabilities, overwhelming maintainers of open-source software, who need better processes to be able to deal with these reports.

Property-based Testing. The technique of property-based testing seems interesting at a glance, but is fundamentally limited to testing properties that can be expressed using code (i.e., it can only ensure functional correctness). In our research, this is a significant problem, since security is not a functional requirement and expressing vulnerabilities on a case-by-case basis does not demonstrate the absence of security issues that are not explicitly tested for. In fact, a fully correct implementation of a cryptographic algorithm may contain side-channel vulnerabilities when executed on a processor. In a practical context, implementers use so-called known answer tests (KATs), that are similar to test cases derived from boundary values, rather than employing property-based testing. However, identifying suitable KATs can be a significant challenge.

3 Guest lecture principles

Requirements engineering. The idea of requirements engineering assumes that properties of the software can be articulated into specific requirements and that this can be done in a black-box manner. Both assumptions seem rather flawed in the context of security: A requirement such as "The system shall be secure." is so vague as to be practically meaningless and it is doubtful that

there exists a process that could (iteratively or otherwise) refine this requirement into something useful without explicitly listing each potential security issue to consider. Doing so without considering the details of the implementation seems incredibly difficult. More broadly, the separation of concerns where agents focus on the how and humans on the why and what presented in the lecture will have devastating consequences for the security of systems. In our concrete context, an implementation that conforms exactly to a given specification and is functionally correct may still contain security issues. These security issues may only become visible at the hardware layer, which is not accessible to software programmers or agents and no amount of requirements engineering (of the software) is going to address these issues.

Human aspects in software engineering. An interesting consequence of the introduction of AI tools into software engineering presented in the guest lecture is the notion of constant change. From a security perspective, this requires careful managing, since any change introduces a risk of novel security vulnerabilities. In a development process, it is easy to imagine that even subtle changes can have significant implications for the security of an implementation. This issue becomes even more pressing when large parts of the implementation are AI-generated in the first place and human understanding is thus limited. If developer roles become more dynamic, it may also be the case that future developers simply lack the expertise to spot security issues.

4 Data scientists, software engineers, and AI engineers

What differences are described between data scientists and software engineers? The book describes data scientists as following an exploratory workflow focused mainly on improving certain metrics of their models, with little regard to other aspects of the produced models. Software engineers are instead described as using engineering principles to create software that solves users' problems while navigating externally imposed constraints.

Since I am not particularly closely associated with either of these roles, it seems difficult to assess the accuracy of the descriptions. However, from an external perspective, this distinction resembles the general split between research and engineering, where qualities that are desirable in research are not reflected in the real world and practically relevant questions are not considered in a research context since they do not exhibit scientific novelty. The book further acknowledges that the distinctions are oversimplified and overgeneralised, thus this characterisation seems reasonable to me.

Production ML and a system-wide view. Since our research does not involve the development of ML-based systems, there is no direct relation to my own research. However, the idea that it is not possible to reason about a system

by reasoning only about its components certainly resonates. In the context of cryptography, it is well known that secure building blocks can be composed to construct insecure protocols, just as it is known that an implementation can never be "secure" on its own, only secure in the context of a specific threat model that must always be considered.

Will data scientists and software engineers remain distinct roles?

Given my limited experience with both roles, it seems difficult to predict any future changes accurately. Based on the impact that AI-based automation has had in simplifying and improving accessibility across a broad range of domains, it seems obvious that this would also be the case for the two roles. A likely scenario may be that data scientists and software engineers will acquire more skills of the other role and both roles will more closely resemble each other. In particular, future software frameworks may make it easier for data scientists to build models in such a way that they can be deployed with only limited engineering work, while machine learning libraries may automate hyperparameter/architecture optimisations in a way that would allow software engineers to train suitable models themselves. Since the current distinctions as described in the book are partially also a matter of preference/interest, it seems unlikely that the roles would be merged entirely.

Where does AI Engineering fit? Based on the descriptions in the book and from the lecture, I get the impression that the term AI Engineering does not following a single universal definition and that the process of AI Engineering is in no small part also dependent on the company culture and the existing processes. The engineering involved in integrating ML features into an existing product is going to look fundamentally different from that involved with building a product centred around ML from the beginning. Since the outcome of this process is closely related, it does not seem reasonable to constrain the term AI Engineering to refer to only one of these approaches.

How are the boundaries changing? AI-based tooling can automate processes and make experimentation more accessible, thereby lifting the level of abstraction at which either role operates. This necessarily also blurs the boundaries between both roles, though likely not enough to fully cause them to disappear.

5 Papers

5.1 SETA: Statistical Fault Attribution for Compound AI Systems [4]

Core ideas and their importance. The paper introduces SETA, a framework for fault attribution in complex machine learning systems. The approach

uses metamorphic testing, in which the expected system behaviour under a certain perturbation is described in the form of properties that must hold (similar to property-based testing described in the lecture) and combines this with an execution tracing approach that enables statistical attribution of faults to specific model components.

In the context of AI system engineering, the paper's contribution is significant, since accurately determining which component of a complex system is responsible for a failure is a prerequisite for improving the performance. Further identifying how errors propagate across components can provide guidance on system-level issues that cannot be identified with component-level testing alone.

Relation to my research. The paper does not have a direct relation to my research. However, the analysis of how errors can propagate from parts of a system to the output is a central aspect of fault injection attack research. Since the approach presented in the paper is tightly coupled to the behaviour of various machine learning components and considers the angle of reliability instead of focusing on an adversarial context, the ideas do not seem to be transferable directly.

Integration into a larger AI-intensive project. Consider a machine learning system used in the context of astrophysics for identification and classification of objects imaged using various telescopes. This system will have at least two major components, one to identify regions of interest/objects within these regions, and one to classify the detected objects. The application of the ideas presented in the paper extend naturally, since the system is quite similar to that given as the example.

In particular, the SETA framework presented in the paper could be used to identify the contribution of poor object detection to classification failures, thereby providing a way to analyse the overall system behaviour as opposed to reasoning only about the individual components. The resulting insights can then be used to improve the existing components or to add additional components that check the correctness (using an ensemble approach).

As mentioned previously, there is no direct relation from the paper to my own research. However, one can easily imagine that there may be a desire to distribute such a detection and classification system by deploying it on devices in the field, which then need to be protected against physical attackers to prevent them from affecting the validity of the results.

Adaptation of my research. A common thread between the underlying challenge in the paper and my own research is resilience of systems against faults. A systematic way of identifying the relationship between errors in components/procedures and the failure of a system would also be an interesting (though practically challenging to achieve) contribution in my own research.

5.2 SoK: Attack and Defense Landscape of Agentic AI Systems [5]

Core ideas and their importance. The paper presents a survey of knowledge on the security of agentic AI systems. The authors establish a framework for describing agentic system through seven design dimensions (input trust, access sensitivity, workflow, action, memory, tool, user interface) and review 128 papers to assess the security risks associated with these models across several categories. They identify seven risks (heterogeneous untrusted interfaces, wrong instruction following, unconstrained data flow, hallucination, private data leakage, unauthorized action, and denial-of-service). They also discuss existing approaches to mitigate these risks.

The relevance of their analysis in the context of engineering of AI systems is obvious. Clearly, existing systems are not sufficiently robust against attacks and developing and implementing suitable countermeasures requires assessing each individual system against known attacks and novel risks. This process must be part of the engineering process and can follow their framework as a starting point.

Relation to my research. The analysis in the paper is to some extent related to my research in that hardware-level vulnerabilities can be surfaced by interactions within the agentic system in a way that makes them exploitable to an attacker. The paper even explicitly mentions the risk for side-channel attacks in the tool execution timing, though also acknowledges that this area is significantly underexplored. It is likely the case that further security issue arise when considering agentic systems from a hardware perspective, and a future analysis from this perspective could use the paper as a starting point.

Integration into a larger AI-intensive project. Since the contribution of the paper is in summarising existing knowledge, not in developing a technique, its integration into a larger project is likely to be non-technical. Consider the integration of a chat bot into a banking application. In order to ensure the security of the bank’s customers, it is of critical importance to analyse the capabilities and security risks related to this chat bot. In particular, the criteria and risks highlighted by the paper need to be analysed within the specific context of the deployment and appropriated countermeasures must be designed, implemented, and tested.

Within the context of this example, my own research may be applicable to the tools that are available to the chat bot to call for answering users’ requests. It is important that the chat bot cannot use these tools in a way that exposes information or otherwise impacts their functionality. However, since the deployment in this scenario does not feasibly allow an attacker physical access to the system, the applicability of my research is overall limited.

Adaptation of my research. Future work in my research area should consider the challenges posed by the broader deployment of agentic systems. It

is foreseeable that these systems will increasingly be deployed on edge devices or in IoT settings, where their resistance to physical attacks will be a significant threat. Developers of these systems will have to confront the challenges of such attacks and research will have to determine where to focus the effort by identifying realistic threats.

6 Evidence and originality

The main source for the first part of this assignment is the course material and the book it referenced. Since these are explicitly recommended by the course, I trust their accuracy.

For the second part of the assignment I relied on two papers. One from a CAIN conference, and one from USENIX Security&Privacy, which is the top venue for security research. The quality of papers at CAIN seemed quite mixed and finding a paper that was openly accessible proved challenging. Since the paper is only available as a preprint and since my expertise in the domain is limited, I cannot fully trust the accuracy of the presented statements and made sure not to rely on technical details in my descriptions. The second paper is available as a pre-published version that has undergone peer-review, is published in a reputable venue, and mainly summarised other published work, hence I trust its accuracy.

I did not use GenAI tools for this assignment.

References

- [1] Heather Adkins and Sophie Schmieg. *Quantum frontiers may be closer than they appear*. URL: <https://blog.google/innovation-and-ai/technology/safety-security/cryptography-migration-timeline/>.
- [2] Ryan Babbush et al. *Securing Elliptic Curve Cryptocurrencies against Quantum Vulnerabilities: Resource Estimates and Mitigations*. 2026. arXiv: 2603.28846 [quant-ph]. URL: <https://arxiv.org/abs/2603.28846>.
- [3] Madelyn Cain et al. *Shor’s algorithm is possible with as few as 10,000 reconfigurable atomic qubits*. 2026. arXiv: 2603.28627 [quant-ph]. URL: <https://arxiv.org/abs/2603.28627>.
- [4] Sayak Chowdhury and Meenakshi D’Souza. “SETA: Statistical Fault Attribution for Compound AI Systems”. In: *arXiv preprint arXiv:2601.19337* (2026). URL: <https://arxiv.org/pdf/2601.19337>.
- [5] Juhee Kim et al. “SoK: Attack and defense landscape of agentic ai systems”. In: *35nd USENIX Security Symposium (USENIX Security 26)*. 2026. URL: https://www.usenix.org/system/files/conference/usenixsecurity26/sec26_prepub_kim-juhee-agentic.pdf.
- [6] Dustin Moody et al. *Transition to Post-Quantum Cryptography Standards*. DOI: 10.6028/NIST.IR.8547.ipd.

- [7] Peter W. Shor. “Algorithms for Quantum Computation: Discrete Logarithms and Factoring”. In: *35th Annual Symposium on Foundations of Computer Science, Santa Fe, New Mexico, USA, 20-22 November 1994*. IEEE Computer Society, 1994, pp. 124–134. DOI: 10.1109/SFCS.1994.365700.
- [8] National Institute of Standards and Technology. *PQC Standardization Process*. URL: <https://csrc.nist.gov/pqc-standardization>.
- [9] Bas Westerbaan. *Cloudflare targets 2029 for full post-quantum security*. URL: <https://blog.cloudflare.com/post-quantum-roadmap/>.